

Physical Security

Think about a school locker. You put your belongings in it to keep them safe from other people. It's made of fairly heavy steel and designed to be hard to pry open. Security folks would call the door an *attack surface* because it's something that someone trying to break into your locker can attack. It's a pretty good response to the threat of theft, because you can't break it open without making a lot of noise. Lots of people are around during the day when your stuff is in your locker, and they would probably notice. Although someone could break in after hours, it's less likely that things of value would be in the locker at those times.

The combination lock on the door opens only with the correct combination, which you know. When the school gave you the combination, they gave you *authorization* to open that particular locker. The lock is another attack surface. The lock is designed so that breaking the dial off doesn't cause it to open and so that it's hard to get to the innards of the lock with the locker closed. Of course, now some new issues arise. You need to keep the combination secret. You can write it down on a piece of paper somewhere, but someone else might find it. You have to make sure that someone else doesn't learn your combination by watching you open your locker. And, as you know from watching movies, safecrackers can open combination locks, and it's not practical for the school to spend the money for really good locks. Devices called *autodialers* can be attached to a combination lock to try all the possible combinations. They used to be specialty devices, but people have built their own using small, inexpensive microcomputers such as Arduinos combined with cheap stepper motors. But just like with the door, enough people are roaming the halls that a break-in attempt would likely be noticed. It would take either a talented safecracker or a bad lock design (as many "tough-looking" locks are all show). Note that there is a popular brand of combination lock that can easily be opened in less than a minute by anyone with easily obtainable knowledge.

There's a third attack surface that may have escaped your notice. There's a keyhole in the middle of the lock. It's what security people would call a *backdoor*, even though in this case it's on the front door. It's another way of getting into your locker that's not under your control. Why is it there? Obviously the school knows the combination to your locker, or they wouldn't have been able to give it to you. This backdoor is there for their convenience so that they can quickly open everybody's lockers. But it reduces everybody's security. Locks with keyholes are pretty easy to pick in seconds. And because one key opens everybody's locker, they're all vulnerable if someone gets a copy of the key, which isn't as hard as you might think.

When the school gave you the combination to your locker, they conferred a *privilege* on you—namely, the ability to get into your locker. Someone with the key has a higher *privilege level*, as they're authorized to open all lockers, not just one. Acquiring a copy of the key would raise your privilege level. Many budding engineers, including this author, discovered locksmithing and found ways to become “privileged” in our youths.

Communications Security

Now that we've learned a little about keeping stuff secure, let's tackle a harder problem. How do you transfer something of yours to someone else? Let's start with an easy case. You have a homework assignment about Orion that's due, but you have to miss class for a doctor's appointment. You see your friend Edgar in the hall and ask him to turn in your homework for you. Seems simple enough.

The first step in this process is *authentication*. This is you recognizing that the person you're handing your homework to is indeed Edgar. But in your rush, you may have forgotten that Edgar has an evil twin brother. Or “Edgar” could be something wearing Edgar, like an Edgar suit. You really don't want to accidentally authenticate something buggy (see the 1997 movie *Men in Black*)!

Edgar impersonators aren't the only attack surface. All bets are off once your homework is out of your hands; you're trusting Edgar to act in your best interest. But Edgar could space out and forget to hand it in. Evil Edgar could change your homework so that some of the answers are wrong, or worse, he could make it look like you copied someone else's work. There's no way to prove *authenticity*—that Edgar turned in what you handed him. If you had planned ahead, you could have put your homework into an envelope secured by a wax seal. Of course, these can often be opened and resealed without leaving a trace.

This becomes a much more difficult problem when you don't have an authenticated, *trusted* courier delivering your homework. Maybe you had an unplanned absence and your teacher said that you could mail in your homework. Any number of unknown people may handle your letter, making it vulnerable to a *man-in-the-middle attack*, which is when an attacker gets between parties and intercepts and/or modifies their communications. You don't know who's handling your mail, and, unlike with Edgar, you don't even have an opportunity for authentication.

The solution to these issues is *cryptography*. You can *encrypt* your communication using a secret code known only to you and the intended recipient, who can use that code to *decrypt* it. Of course, like your locker combination, the secret code must be kept secret. Codes can be broken, and you have no way to know if someone knows or broke your code. A properly designed *cryptosystem* reduces the need to trust components between parties; leaked communications that can't be read aren't as big a risk.

Codes get changed when their users figure out that they've been broken. An interesting aspect of World War II code breaking was the various ruses concocted to camouflage actions resulting from broken codes. For example, sending out an airplane to “accidentally” spot fleet movements so that the fleet could be attacked hid the fact that code breaking was how the location of the fleet was actually determined. Neal Stephenson's novel *Cryptonomicon* is a highly entertaining read about this type of information security.